Privacy and security note: Udyam Digital

The prototype handles small-business onboarding for Accel Business. All the data in it is synthetic, but we built it as if the data were real and covered by the DPDP Act, 2023.

Consent per purpose. Before KYC the owner sees a short notice in English or Hindi. Each purpose is listed on its own: checking the business documents for this order (required), and using anonymised details to improve the service (optional). Each consent stores the notice version (for example `2026-07-v1`) and the purposes accepted. Withdrawing consent deletes that order's KYC data and results.

Data minimisation. Each step asks only for what it needs:

- The advisor needs the business type, size, city and needs.
- The quote needs a GSTIN only for products that require one, and checks it against the registry.
- KYC needs the business registration, Udyam certificate, signatory ID and a recent address proof.
- The order needs a contact name and phone number.

We never collect Aadhaar. The signatory ID check uses another ID document.

Documents are read in memory. Photos are uploaded over HTTPS, read by on-server OCR (RapidOCR) and checked against the GSTIN and Udyam registries. Then they are discarded and never written to disk. We keep only the result: the checks, the verdict and masked fields.

Retention.

- KYC results and consent records are kept for 180 days after activation, then deleted.
- If an application is rejected, they are deleted after 30 days.

Masking and encryption.

- GSTIN, Udyam number, ID number and phone number are masked in every API response, screen and log line, for example GSTIN `27QH••••••••1ZL`, phone `••••••3210`.
- Server logs pass through a redaction filter.
- Phone numbers are encrypted at rest (Fernet).
- The order tracker opens only with the order ID and a PIN.

The LLM sees only the business description. The advisor sends the owner's words about the business to an LLM: Groq first, Gemini as fallback. If neither responds, a rules-only mode answers. The LLM never receives IDs, phone numbers, documents or images. A deterministic rules engine decides eligibility and price, so the LLM can explain a recommendation but cannot invent a product or a price.

Back office. The leads, handoffs, KYC reviews and orders screens sit behind a passcode header. They show masked identifiers only. Demo-only controls (sample applicants, "advance order") work only when demo mode is on.

Synthetic data only. All businesses, people, GSTINs, Udyam numbers and documents come from the hackathon pack and are fictional. GSTINs use an impossible PAN entity type, and Udyam numbers use a district code that does not exist.

What production would add.

- DigiLocker pull of verified documents with the owner's consent, instead of photos.
- Aadhaar e-sign for the order form.
- An append-only audit log of every access to personal data.
- Role-based access with named users and SSO for sales, partners and KYC reviewers, in place of a shared passcode.
- Key management in a KMS, a data-processing agreement with each LLM provider, and a published grievance contact.